

VideoFly 网站全量质量检查

阶段总结（6 阶段审计 + 统一修复，累计完成）

审计目标	保障网站正常使用；检查前后端一致性、安全、Bug、鉴权与调用链路
当前进度	6 个审计阶段与统一修复均已完成；进入部署前真实环境冒烟门禁
当前状态	8 个有效问题已全部修复：3 个高、4 个中、1 个低；当前活动确认问题为 0
下一阶段	注入完整生产环境变量，在可清理环境验证真实 Provider、支付、数据库与存储

一、总体结论

阶段性判断：全量审计 6 个阶段和统一修复均已完成；8 个有效问题全部关闭，当前无仍处于打开状态的已确认源码缺陷。

证据强度：27 项功能测试、211 项全量测试、生产构建、类型检查、Lint、依赖审计、密钥扫描、机械复核和最终质量门禁均有运行凭证。

最终结果：8/8 个确认问题已修复并复核；全量测试 211/211 通过，质量门禁 0 项失败、3 条旧清单兼容提醒。

二、第 1 阶段：全量探索

覆盖范围：鉴权与权限、视频生成、Provider 路由、AI 回调、QStash 对账、积分账本、Stripe、上传与存储、生成器前后端接口。

规模：672 个 Git 跟踪文件，其中 465 个位于 src；采用 200–500 源文件项目的深度范围声明。

探索产出：14 条带文件行号的事实发现、8 个后续候选项、4 个完整模式走查，入口门槛 13/13 通过。

明确不纳入：营销页面视觉、体验优化、非关键文案，以及遗留 Kubernetes/tRPC 模块的深度审计。

第 1 阶段确认的正向防线

- 未登录敏感 API 返回 401，管理员 API 对未授权请求返回 403。
- 管理员权限从数据库实时读取，避免撤权后仍依赖旧 Cookie 缓存。
- 生成入口校验上传图片归属，用户身份由会话得到。
- 前端模型选项与服务器模型能力校验使用共享目录和积分计算逻辑。
- AI 回调具备 HMAC、时间窗口、Provider 与外部任务 ID 绑定。
- 积分冻结、结算和释放具备锁与幂等状态判断。
- 远程媒体已有 HTTPS、私网地址、重定向和字节数限制。

三、当前确认问题与闭环状态

级别	问题	正常使用影响	追踪
驳回	Stripe /dashboard 死链	中间件已实现可用重定向；原结论是路由枚举误判。	Finding 001 / 已关闭
高	长任务对账窗口耗尽后悬挂	已修复：60 分钟终态策略，并保护进行中的上传租约与积分结算。	REQ-007 / BUG-002 / FIXED
驳回	Bailian 回调入口缺失	代码实现轮询完成路径，且仓库契约未要求所有 Provider 支持回调；早期文档引用已撤回。	Finding 003 / 已关闭
中	AI 回调请求体没有应用级上限	已修复：声明长度和实际流量均受 1 MiB 上限约束，异常 JSON 返回 400。	REQ-006 / BUG-004 / FIXED
中	回调密钥文档变量不一致	已修复：活动指南、示例环境和可执行代码统一使用 CALLBACK_HMAC_SECRET。	REQ-012 / BUG-005 / FIXED
低	CSP 拦截 Vercel 观测脚本	已修复：CSP 精确允许已启用的 Vercel 观测脚本源。	REQ-014 / BUG-006 / FIXED

级别	问题	正常使用影响	追踪
高	DNS 校验未绑定实际媒体连接	已修复：每次连接和重定向均使用已验证公网 IP，并保留 Host/SNI、代理、限额和清理。	REQ-010 / BUG-007 / FIXED
中	积分流水类型在 API/UI/翻译间不一致	已修复：API、类型、UI 和 7 种语言使用同一完整词汇，含 payment_reversal。	REQ-013 / BUG-008 / FIXED
高	QStash 调度端与接收端密钥要求不同	已修复：发送、接收和失败回调共享完整 QStash 配置契约，部分配置不再误调度。	REQ-007、012 / BUG-009 / FIXED
中	作品筛选控件未传递筛选条件	已修复：状态、模型、排序进入数据库查询；升序分页方向同步修正。	REQ-013 / BUG-010 / FIXED
覆盖缺口	缺少付费生成完整链路测试	真实 Provider、支付和存储联调仍需授权环境；当前本地证据不冒充线上验证。	CAND-008 / 保留

四、第 2 阶段：质量制品生成

行为契约：提取并归纳 38 条核心行为契约，覆盖权限、生成输入、积分与视频状态、Provider、回调、媒体安全、Stripe 和部署配置。

需求与用例：形成 12 条可测试需求和 7 个端到端用例；每条需求包含代码证据、适用用例和明确满足条件。

质量场景与自动检查：形成 10 个真实故障场景，新增 27 项 Vitest 功能测试并全部通过；机械脚本可重复提取 Provider 清单及 Bailian 回调差异，后续确认该差异对应轮询能力。

后续执行协议：已生成代码审查、集成测试、规格审计和红绿 TDD 四份执行协议，保证后续阶段按同一证据标准进行。

第 2 阶段验证结果

检查	结果	说明
功能测试	通过	27/27；全量测试 211/211

TypeScript	通过	无类型错误
Lint	通过	395 个文件，无错误
机械枚举	通过	通过；Provider 制品与源码一致
制品门槛	通过	质量门禁 0 FAIL、3 个旧清单兼容 WARN

五、第 3 阶段：代码审查与回归设计

三轮审查：结构审查、逐需求审查和可执行确认均已完成；12 条需求全部给出满足、违反或待证明结论。

第 3 阶段当时结论：初步确认 BUG-001 至 BUG-006：2 个高、3 个中、1 个低；后续挑战审查撤回 BUG-001 与 BUG-003。

第 3 阶段模式网格：REQ-005 的 5 个积分状态单元均有补偿；REQ-007 的 2 个耐久对账缺口归入 BUG-002；REQ-011 的 Bailian 差异当时归入 BUG-003，后续确认其为轮询能力差异并撤回。

补丁与写案：已生成 6 个预期失败回归补丁、6 个拟议修复补丁和 6 份独立问题写案；12 个补丁全部通过 git apply --check。

验证基线：完整测试 182/182 通过，TypeScript 与 Lint 通过，产品源码保持不变。

六、第 4 阶段：规格审计与分诊

独立审计：从产品运营、安全财务、实现一致性三个视角复核全部 12 条基线需求，并补充 REQ-013 前后端数据契约。

重要纠偏：BUG-001 已撤回：/dashboard 由中间件实现为重定向；旧回归和修复补丁均标记为不得应用。

新增确认：新增 BUG-007 至 BUG-010：DNS 连接绑定、积分流水词汇、QStash 密钥一致性和作品筛选链路。

第 4 阶段当时风险：有效 9 个问题：3 高、5 中、1 低；第 5 阶段挑战审查随后撤回 BUG-003，最终有效问题为 8 个。

第 4 阶段验证：10 项分诊探针符合当时预期；完整测试 192 项、类型检查、Lint 和 19/19 补丁检查通过。

引用复核：本轮 13 条需求全部为代码推导，Tier 1/2 引用数量为 0，因此语义引用检查按协议为空结果，不伪造跨模型投票。

七、第 5 阶段：对账、挑战复核与 TDD 闭环

挑战复核：对所有触发项执行两轮反方审查；Bailian 已实现轮询，仓库契约未要求回调入口，因此该发现被驳回；早期引用的 Provider 对照表与 Bailian 无关，已在最终核验中撤回。

回归闭环：8 个有效问题全部获得命名回归测试并在未修改代码上产生 RED 证据；回归套件使用严格预期失败标记，不污染正常 CI。

绿灯验证：BUG-002、004、005、006、009、010 的拟议补丁通过 GREEN；BUG-008 的补丁仍漏支付撤销翻译，明确记录为 GREEN 失败。

安全保留：BUG-007 只确认缺陷、不批准仓促修复；连接固定方案必须同时兼容代理、逐跳重定向校验、流式限额和连接资源释放。

需求对账：新增 REQ-014 约束已启用观测脚本与 CSP 的一致性；8 个有效问题现均可追溯到明确需求。

门禁结果：质量门禁 0 项失败；完整测试 184 项通过、16 项预期失败，类型检查、Lint、机械验证和 19/19 补丁检查通过。

第 5 阶段当时源码状态：所有红绿验证均在一次性隔离工作区完成并清理；当时主工作区尚未修改网站产品源码。

八、第 6 阶段：最终验证与交付门禁

机械闭环：严格重跑原始 Bash 提取验证，Provider 清单制品与当前源码完全一致，退出码为 0。

最终门禁：Quality Playbook 最终门禁记录 93 条 PASS、0 条 FAIL、3 条旧版清单兼容 WARN；警告不代表产品功能通过。

完整验证：27/27 功能测试通过；全量测试 184 项通过、16 项预期失败；类型检查、Lint 和 Next.js 生产构建通过。

制品修正：清理两处被后续证据推翻的旧描述，撤回不适用于 Bailian 的规格引用；补齐 111 行字段参考表、结构化集成结果、JUnit 与写后校验要求。

一致性检查：14 条需求在需求文档、覆盖矩阵与进度记录中的数量一致；8 个问题、测试、补丁、写案和日志均可相互追踪。

第 6 阶段当时发布判断：审计已完成，但 8 个问题尚未统一进入产品源码，因此当时建议保持 BLOCK。

第 6 阶段当时源码状态：产品源码尚未修改；统一修复在用户后续明确授权后执行。

九、统一修复：8 个问题全部落地

执行方式：在用户明确授权后一次性修改产品源码，并保留原始 RED 证据；所有活动回归已由预期失败改为普通通过测试。

- 高风险闭环：BUG-002 增加 60 分钟终态与上传租约竞态保护；BUG-007 将实际连接固定到已验证公网 IP；BUG-009 统一 QStash 发送端、接收端和失败回调的完整配置要求。
- 其余闭环：回调请求体限制为 1 MiB；修正文档密钥名和 Vercel CSP；统一积分流水词汇并补齐 7 种语言；贯通作品状态、模型、排序与数据库分页。
- 验证结果：211/211 测试、TypeScript、Biome、Next.js 生产构建、依赖漏洞审计、已跟踪文件密钥扫描、机械验证和 Quality Playbook 门禁全部通过。
- 剩余部署门禁：本轮未调用真实付费 Provider、支付和对象存储；上线前仍需在可清理测试环境注入完整环境变量并执行一次真实冒烟测试。

十、审计与统一修复文件位置

仓库证据：F:\saas411\quality\

核心入口：EXPLORATION.md、REQUIREMENTS.md、QUALITY.md、CONTRACTS.md、COVERAGE_MATRIX.md、PROGRESS.md。

本总结：C:\Users\Administrator\Desktop\VideoFly 网站全量质量检查阶段总结.docx

十一、上线前最终全链路检查 (2026-08-05)

发布裁决：FIX BEFORE MERGE。代码门禁通过，但存在 1 个高危 DOM XSS、最新预览部署失败，且统一修复尚未部署到当前生产版本。

检查范围：公开页面、登录入口、普通用户/管理员 API、AI/Stripe/QStash 回调、Cron、模型目录、积分与视频链路、存储入口、环境变量、线上日志、安全响应头及桌面/移动端浏览器行为。

版本边界：工作区分支 agent/security-release-hardening，HEAD e781082，包含尚未提交的统一修复；当前生产仍为 main 的 53ab7c0。

1. 必须在合并前解决

- **SEC-011 (高危, 高置信度)：**src/components/credits/credits-page.tsx 第 62-83 行把 returnTo 查询参数经二次 decode 后直接传给 router.push。登录用户访问攻击链接时可形成开放跳转，并可能执行 javascript: URL。必须改用现有 getSafeAuthCallbackURL 白名单校验并补负向测试。
- **REL-011 (发布阻断)：**最新分支预览部署 dpl_Df8z9VWTqrCE9DULxeM3UYeiAit3 为 ERROR；构建日志确认 Preview 环境缺少 BETTER_AUTH_SECRET 与 NEXT_PUBLIC_APP_URL。需补齐 Preview 作用域变量并获得 READY 预览。
- **REL-012 (版本阻断)：**8 项统一修复当前只在本地工作区，尚未提交、未产生绿色预览、未进入生产；线上仍可复现旧版翻译缺失。

2. 自动化与线上门禁证据

门禁	结果	证据
TypeScript	PASS	tsc --noEmit，无错误
Biome	PASS	395 个文件，无错误
全量测试	PASS	33 个测试文件，211/211 通过
生产构建	PASS	Node 24 + Next.js 15.5.21；SKIP_ENV_VALIDATION=1 时完成 182 个静态页面
依赖漏洞	PASS	pnpm audit --prod --audit-level high：无已知漏洞
密钥扫描	PASS	当前文件、受控敏感文件与 Git 历史均无真实高置信度凭据命中
鉴权负测	PASS	普通接口 401；管理员接口 401/403；Cron、AI、Stripe、QStash 均拒绝无签名请求
OAuth 初始化	PASS	同源 Google 登录请求 200，回调为 /api/auth/callback/google；缺失 Origin 请求被 403 拒绝
浏览器冒烟	PASS	首页、定价、登录、注册、工具页均 200；未登录生成/购买不触发费用；390px 无横向溢出
机械复核	PASS	Provider 机械制品与源码一致
Vercel 预览	FAIL	最新分支部署因 Preview 环境变量缺失而失败

3. 已确认的非核心线上问题

- 当前生产文本/图生视频页仍报 Credits.packages.team.name/description 缺失；修复后本地生产包中英文均已无该错误，部署新版本后应复验。
- 未登录首页、定价页和工具页会请求受保护的积分/素材接口并产生预期 401 控制台错误；不阻断使用，但会污染监控。
- 线上 sitemap.xml 返回 200 但 URL 数为 0；运行时扫描 /var/task/src/app/[locale] 失败。属于 SEO/发布完整性缺陷，不影响核心生成链路。
- 无签名 video-reconcile 请求被 QStash 正确拦截，但主入口返回 500 而非 401/403，可能造成误报警。

4. 今天上线前必须人工完成

- 修复 SEC-011 并添加 javascript:、https://、//evil.example、畸形百分号四类负向测试；重新跑 211 项测试、类型、Lint 与构建。
- 在 Vercel Preview 作用域补齐所需变量，确认预览部署 READY；再核对 Production 变量名称与作用域，不展示或复制真实值。
- 用专用测试账号分别完成 Google 登录、邮箱 OTP、退出与重新登录；普通账号访问 /admin 必须拒绝。
- 上传一张小尺寸真实图片，确认 presign → PUT → complete → 素材列表；用第二账号确认不能引用第一账号图片。
- 执行一次最低成本 Evolink 生成，观察积分冻结、任务 ID、回调或 QStash、R2 入库、COMPLETED 与积分结算；再做一次可控失败并确认释放积分。
- 仅在 Stripe 测试模式完成一次订阅与一次积分包支付，确认 webhook 幂等、订单/积分账本、支付返回页；不得用真实银行卡做上线验证。
- 管理员检查 Provider Health、用户/角色、视频恢复入口；发布后 15 分钟检查 Vercel 5xx、回调、数据库连接、QStash 与存储日志。
- 确认生产别名 seedance.co.com 指向本次目标 SHA，并复测首页、登录、生成、积分、作品列表与安全响应头。

5. 安全审查结论

安全发现汇总：严重 0，高危 1，中危 0，低危 0；生产依赖漏洞 0；真实凭据暴露 0。

已验证安全边界：SQL 均通过 Drizzle 参数化；用户资源查询携带 userId；管理员角色实时查库；上传绑定预约与所有权；回调/定时任务需要签名或密钥；OAuth 缺失同源 Origin 被拒绝。

十二、修复后最终验收检查点 (2026-08-05)

当前验收状态: BLOCK。高危代码问题已经修复且本地门禁全绿，但最新 Preview 仍因缺少四个环境变量而构建失败；账号、上传和真实生成链路尚未完成登录态验收。

1. 已完成并通过

- SEC-011 已修复：积分页 `returnTo` 现在通过 `getSafeAuthCallbackURL` 只允许站内路径，不再重复 `decodeURIComponent`。
- 回归测试完成红绿验证：旧代码上安全测试失败，修复后定向测试 8/8 通过。
- 全量测试 34 个文件、213/213 通过；TypeScript、Biome、生产构建、依赖审计、机械校验和 git diff 检查均通过。
- 生产构建生成 182 个静态页面；本地 sitemap 构建阶段生成 84 个 URL。

2. Vercel 复验结果

- 用户已将 `BETTER_AUTH_SECRET` 与 `NEXT_PUBLIC_APP_URL` 配置为 Production and Preview。
- 用户触发的成功重新部署 `dpl_9wDquG52sCGnVZVBNXTWuhKoVN2u` 是 production 旧提交 `53ab7c0` 的重新部署，不包含本地高危修复。
- 从当前工作区创建的 Preview `dpl_HrB4VD4Lp9KtBMS3Bn8v9PKGtYWi` 构建失败；远端日志确认 Preview 还缺 `GOOGLE_CLIENT_ID`、`GOOGLE_CLIENT_SECRET`、`RESEND_API_KEY`、`RESEND_FROM`。
- 生产站未被本次 Preview 尝试替换或中断。

3. 用户下一步只需完成

- 在 Vercel Environment Variables 中把 `GOOGLE_CLIENT_ID`、`GOOGLE_CLIENT_SECRET`、`RESEND_API_KEY`、`RESEND_FROM` 这四个现有变量也勾选 Preview；不要在聊天中发送变量值。
- 完成后回复“4 个 Preview 变量已设置”；由 Codex 重新创建 Preview 并检查到 READY。
- 在 Edge 打开 `seedance.co.com` 并登录普通测试账号，保持页面打开后回复“普通账号已登录”；管理员账号稍后同样切换验证。

4. 待完成的最终链路

- 普通用户登录、退出、重新登录及普通用户拒绝访问管理后台。
- 真实小图片上传、素材入库及第二账号跨用户引用拦截。
- 一次最低成本真实积分视频生成：冻结积分、供应商任务、异步完成、R2 入库、作品可见和积分结算。

- 管理员 Provider Health、用户角色和任务恢复入口。
- 生产发布后目标 SHA、核心页面和 15 分钟运行日志观察。